

Executive Policy Gap & Risk Analysis Report

Stage 5 Governance - Project 1 Deliverable | Candidate ID: UBI-2026-0158

1. Executive Summary

This report records the comprehensive evaluation, risk assessment, and technical remediation of core infrastructure governance gaps under the mandatory 720 staff-hour budget constraint. By transitioning legacy configurations to an automated Open Policy Agent (OPA) and Rego framework, we eliminated critical exposures across privileged identity assurance, restricted storage protection, and managed endpoint health baselines.

2. Identified Control Gaps & Remediation Matrix

a. G-001: Privileged Identity Assurance (NIST PR.AC-07 / ISO A.9.4.2) || Priority: High

- **Finding:** Legacy configuration allowed weak multi-factor authentication vectors and unvalidated tokens on administrative accounts.
- **Remediation:** Implemented strict fail-closed Rego validation rules (`policy-bundle/policy.rego`) ensuring all privileged human actors enforce robust MFA verification before session authorization.

b. G-002: Restricted Storage Protection (NIST PR.DS-01 / ISO A.8.24) || Priority: High

- **Finding:** Potential public-read exposures and unencrypted cloud storage buckets found in staging assets.
- **Remediation:** Enforced mandatory cryptographic encryption at rest and blocked public ACL exposure vectors via automated OPA policy rules validated through test fixtures.

c. G-003: Managed Endpoint Health (NIST DE.CM-08 / ISO A.8.8) || Priority: Medium

- **Finding:** Unmanaged or outdated workstation endpoints lack active compliance telemetry verification.
- **Remediation:** Established automated endpoint health baseline validation checks to continuously flag non-compliant worker nodes.

Executive Policy Gap & Risk Analysis Report

Stage 5 Governance - Project 1 Deliverable | Candidate ID: UBI-2026-0158

3. Resource Budget & Deferred Risk Governance

All core technical deliverables were successfully completed within the strict 720 staff-hour board budget. Peripheral edge-case telemetry variations and lower-priority network boundary items have been formally postponed to the following quarterly remediation cycles as documented in the project decision ledger.